

Grunenthal_information_security_check

Information Assurance

1. **Has the organization implemented and documented an information security program and policy that is communicated, monitored, maintained, continually improved, and approved by management?** [客户标注 high risk, 客户评论 Please provide evidence of a information security policy]

We adhere to industry-standard security frameworks and best practices, including ISO 27001 guidelines, to ensure a robust and systematic approach to information security. Our policies cover data access controls, encryption standards, incident response, and regular security audits. They are also reviewed and updated on a regular basis by the CEO, Data-Security Administrator, and DevOps Manager to address emerging threats and incorporate the latest security advancements. Performance metrics, such as incident response times and vulnerability remediation rates, are tracked and analyzed to ensure continuous improvement.

2. **Is there a documented risk assessment process for information security with consistent and comparable results?** [客户标注 high risk, 客户评论 Please provide evidence of a documented risk assessment process]

Yes, we have a rigorous and documented risk assessment process. ChemAIRS demonstrates security practices including:

- A. Regular vulnerability assessments combining tools and manual testing by professionals (conducted annually for application security)
- B. SonarQube integration in CI/CD flow for code vulnerability detection
- C. Trivy automation for container image security scanning
- D. Regular security vulnerability scans on per-release and online environments
- E. Regular engagement of third-party security firms to conduct security audits and assessments

Asset and Info Management

3. **Is there an asset management program approved by management, communicated to constituents and an owner to maintain, review, and manage asset controls?**

Yes. The organization has an asset management program:

- Dedicated information security team: Internal specialized team responsible for daily information security and asset management
- Clear ownership: Information security team maintains, reviews, and manages asset controls
- ISO 27001 certification: Requires documented asset management policies, regular reviews, and management approval
- Scope: Covers employee computers, network devices, servers, databases, applications, and security tools

4. Is there an acceptable use policy for information and associated assets that has been approved by management, communicated to appropriate constituents, and assigned an owner to maintain and periodically review the policy? [客户标注 high risk, 客户评论 Please provide evidence of a acceptable use policy]

Yes. The organization has an asset management program:

- Dedicated information security team: Internal specialized team responsible for daily information security and asset management
- Clear ownership: Information security team maintains, reviews, and manages asset controls
- ISO 27001 certification: Requires documented asset management policies, regular reviews, and management approval
- Scope: Covers employee computers, network devices, servers, databases, applications, and security tools

5. Is there a records retention policy and retention schedule covering paper and electronic records, including email in support of applicable regulations, standards, and contractual requirements?

Yes. ChemAIRS has the following retention policies:

- Personal information retention: 6 months after termination of the usage agreement
- Audit log retention: 6 months (default, depends on storage size)
- System log retention: 60 days
- Data backup: Daily full backups with 7 generations

[Note: remove "partially"]

Human Resources Security

6. Are constituents required to attend security awareness training, including techniques to recognize phishing attempts?

Yes. All employees undergo two mandatory security training every year to ensure they understand and comply with information security policies.

Physical and Environmental Security

7. Has management approved a physical security program that is communicated to all parties involved, with an assigned owner responsible for maintenance and review and do the physical security controls cover all secured facilities e.g., data centers, office buildings?

Yes. ChemAIRS has implemented:

- VLAN segmentation and data isolation within the office's foundational network architecture.
- For data in the online environment, only temporarily authorized administrators can access and view it on dedicated servers within the same network segment.
- No data is permitted to be taken out except with proper authorization.
- Connection sources to dedicated servers are strictly restricted, allowing only specific devices.
- Physical security for AWS data centers (for SaaS deployments) with internal-only private network (VPC) based cluster deployment and limited authorized AWS management platform access.
- Physical servers are hosted in professional IDC (Internet Data Center) facilities.

IT Operations Management

8. Is there an operational Change Management/Change Control policy or program that has been documented, approved by management, communicated to appropriate constituents, and assigned an owner to maintain and review the policy?

Yes. The configuration and updates of ChemAIRS require an internal modification approval process. Changes can only be made after being reviewed and approved by the development lead and the data security lead.

9. Are Information Security requirements specified and implemented when new systems are introduced, upgraded, or enhanced?

Yes. ChemAIRS implements comprehensive security measures during development and deployment. ChemAIRS accesses SonarQube's quality management and vulnerability detection engine at code compilation time (CI/CD). Vulnerabilities in the reference chain are

identified in daily reports and reviewed by the code security team before being submitted to the code owner for repair, and only after the repair is complete will the merge-in request be approved. At release time, the code artifact will be built as a container image and released to the pre-release project. In the privately deployed Harbor repository, we use the Trivy engine to scan the image, and once a risky vulnerability is found, it will be reviewed by the code security team and submitted to the Devops administrator for fixing. After the release of the version, we will also have a quality management team for the pre-release environment and online formal environment from time to time security scanning. Once any problem is found, it will be reported to the code security team to review and submit to the person in charge of the corresponding repair.

Access Control

10. Has management approved an access control policy, communicated it to constituents, appointed an owner to maintain it, and reviewed it?

Yes. ChemAIRS has implemented:

- User tenant and RBAC (Role-Based Access Control)
- Account management policies
- Password policies
- Access log auditing
- Access rights can be set per user and per administrator

11. Has management approved, communicated, and enforced a password policy for systems that transmit, process, or store scoped data on all platforms and network devices including specific length and complexity requirements and require keeping passwords confidential? [客户标注 high risk, 客户评论 Please provide evidence of a password policy]

Yes. The password policy includes:

- Minimum length: 8 characters
- Complexity: Must include at least 3 of the following 4 types:
 - English uppercase letters
 - English lowercase letters
 - Numbers
 - Special characters
- Prohibited passwords: User account names, user email addresses, common simple passwords, or historical passwords are banned

- Storage: Passwords stored in hashed and salted format

12. Is there a process for identifying, maintaining, and reviewing access e.g., periodical review, role changes etc.?

Yes. ChemAIRS has:

- Account management rules that include periodic reviews
- IDs issued individually with minimum access rights
- Shared accounts are generally prohibited
- Each account can only be logged in on one device

13. Are unique IDs required for authentication to applications, operating systems, databases, and network devices?

Yes. IDs are issued individually and granted with minimum access rights. Shared accounts are generally prohibited. For privileged access, IDs are issued individually and can be traced to specific users.

14. Does the password policy require passwords to be encrypted in transit?

Yes. ChemAIRS uses:

- Enforced HTTPS protocol for all data; TLS 1.3 (preferred) and TLS 1.2 encryption for data during transmission
- We use AES 256 encryption for important and sensitive data at rest

Cybersecurity Incident Mgmt

15. Has management approved and communicated a Cybersecurity Incident Management Program with a designated owner to maintain and review it?

Yes. ChemAIRS has established a professional incident response team is set up to monitor and alert the main recipients and observers of information, responsible for monitoring, identifying and responding to security threats. Team members include security experts, operations and maintenance personnel, and development leaders. Clearly formulated emergency response process, including steps such as incident categorization, initial assessment, threat isolation and impact mitigation. Analysis and improvement will also be carried out afterwards to thoroughly investigate security incidents, analyze the causes, and optimize existing security policies and response plans.

16. Does the organization have a documented Incident Response Plan that outlines the escalation process? [客户标注 high risk, 客户评论 Please provide evidence of a documented Incident Response Plan that outlines the escalation process]

Yes. The incident response plan includes steps such as incident categorization, initial assessment, threat isolation, and impact mitigation. In the event of a catastrophic failure, the ChemAIRS team sends notification emails to relevant users through the Ops system, and the client's dedicated business manager is contacted individually. (Note: we can use this doc [ChemAIRS SaaS Environment Data Security Management Regulations](#))

17. Is there a specific methodology to regularly review events on scoped systems or systems containing scoped data to uncover potential incidents?

Yes. A monitoring system is deployed to monitor business, system logs, and network traffic in real-time with timely alert notifications. The ChemAIRS team uses Grafana Loki and AWS CloudWatch for real-time monitoring. Intrusion detection and firewalls are deployed at the network and hardware levels to detect abnormal behavior. The company also subscribes to the latest threat intelligence feeds.

18. Does regular security monitoring include alerts for malware infections and suspicious activity? [客户标注 high risk, 客户评论 Please provide evidence that regular security monitoring include alerts for malware infections and suspicious activity]

Yes. The monitoring system includes real-time alerts for suspicious activity. The ChemAIRS team employs advanced hardware firewalls, AWS GuardDuty for intrusion detection, and the data security team conducts continuous surveillance for unusual activities. Application security includes WAF, regular patching, and vulnerability management.

Operational Resilience

19. Is there a formal, documented information technology disaster recovery exercise and testing program in place?

Yes. Operations such as emergency recovery and system rebuilding for failures are practiced from time to time to ensure the recoverability and availability of backups. The quality management team performs automated recovery tests on backup copies on a regular basis to verify the availability of the recovered system and data integrity. (Note: we can use this doc [ChemAIRS SaaS Environment Data Security Management Regulations](#))

20. Are there any dependencies on critical third party service providers?

Yes. For SaaS deployments, ChemAIRS depends on AWS services including RDS, EKS, and other cloud infrastructure components. However, we do not use subcontractors.

21. Is there a pandemic/infectious disease outbreak plan?

Yes, we have a plan according to municipal and regional regulations, but not explicitly internally documented.

22. Is scoped data backed up and stored offsite?

Yes. Daily full backups are performed (7 generations), with data stored in multiple physically isolated availability zones. For SaaS environments, copies of data are dumped into dedicated storage servers. The backup policy ensures safety and reliability of business-critical data.

23. Have formal procedures for business continuity been developed and documented?

Yes. ChemAIRS runs in high availability SaaS services with multi-copy instances in different availability zones to guarantee fast recovery and switching in case of disaster. If the cloud provider's high availability service fails, their application and data separation with distributed containerized architecture can be quickly recovered in a newly built cluster. We have documented notification procedures for disaster events. (Note: we can use this doc [ChemAIRS SaaS Environment Data Security Management Regulations](#))

Endpoint Security

24. Does the organization facilitate the implementation of endpoint security controls? [客户标注 high risk, 客户评论 Please provide evidence that the organization facilitates the implementation of endpoint security controls]

Yes, the organization implements endpoint security controls on employee computers:

- Audit software installed: All company employee computers have audit software installed
- Operation tracking: The audit software enables tracking and auditing of operations performed on endpoint devices
- Traceability: Operations can be traced and audited retrospectively for security and compliance purposes

25. Does the organization restrict the connection of personally-owned, mobile devices to organizational systems and networks?

Yes, the organization implements strict network segmentation to restrict personally-owned devices. Personal devices are segregated from organizational systems and networks through this VLAN separation, preventing access to internal company resources.

26. Is there a mobile device management program in place that has been approved by management and communicated to appropriate constituents?

Yes, we have but not explicitly documented.

27. Can constituents access corporate e-mail using mobile devices? If yes, provide a security concept! (MDM, interface between e-mail apps allowed?)

Yes, employees can access corporate email using mobile devices. (note: no MDM and other limits at this moment)

28. Are non-company managed computing devices used to connect to the company network? If yes, provide a security concept! (Conditional Access Policy, MFA, read-only, encryption, etc...)

No. Only accessed via company PC.

Network Security

29. Does the organization have a Network Security Program with a defined policy that outlines security requirements (including but not limited to email, web, and file transfer services), is reviewed regularly by an owner, and communicated to relevant parties? [客户标注 high risk, 客户评论 please provide evidence of a Network Security Program]

Yes. ChemAIRS has implemented comprehensive network security including:

- Enforced HTTPS protocol for all data; TLS encryption (TLS 1.3 preferred, TLS 1.2 supported) for all data
- Intrusion detection and firewalls at network and hardware levels
- AWS GuardDuty for intrusion detection
- AWS WAF (Web Application Firewall) for protection
- Real-time monitoring of network traffic
- All Kubernetes services are set to ClusterIP to ensure security (except web services)
- ChemAIRS production environment and test environment are networks isolated from each other via VLAN segmentation

30. Is every connection to an external network terminated at a firewall e.g., the Internet, partner networks? [客户标注 high risk, 客户评论 Please provide evidence that every connection to an external network is terminated at a firewall e.g., the Internet, partner networks]

Yes. The system employs:

- Advanced hardware firewalls
- AWS GuardDuty and WAF services
- Only ports 443 and 80 are allowed (80 redirects to HTTPS)
- All services except frontend web services are only internally accessible

31. Is all scoped data sent or received electronically encrypted in transit while outside the network?

Yes. ChemAIRS uses:

- Enforced HTTPS protocol for all data; TLS 1.3 (preferred) and TLS 1.2 encryption for all data during transmission
- We use AES 256 encryption for important and sensitive data at rest
- All data transmission between user devices and servers is secured using industry-standard encryption protocols

32. Are all network devices patched with all available high-risk security patches applied and verified?

Yes. The patching process includes:

- There is no fixed frequency for system updating patches for infrastructure (determined by AWS push mechanism for SaaS deployments)
- Applications are built as container images with patches typically updated automatically with each version release (usually monthly)
- SonarQube integrated into CI/CD for vulnerability detection
- Trivy scanning for container images with the latest real-time CVE vulnerability database
- Regular security vulnerability scans by the quality management team
- All high-risk security patches are applied before release

33. Has management approved a policy for remote access to scoped systems and data communicated to constituents? [客户标注 high risk, 客户评论 Please provide evidence of a remote access policy]

Yes. For remote access:

- Connection sources to dedicated servers are strictly restricted, allowing only specific devices
- All remote connections must be used in conjunction with access authorization
- For SaaS: AWS security group controls (also used in ELB)
- The system can restrict access to client IPs via AWS security group
- SSO integration supported (Azure AD fully tested)
- MFA is in development

34. Are Network Intrusion Detection / Prevention Systems (NIDS/NIPS) used to detect and/or prevent intrusions into the network?

Yes. ChemAIRS employs:

- AWS GuardDuty for intrusion detection
- Intrusion detection and firewalls deployed at network and hardware levels to detect abnormal behavior

- Real-time monitoring of system logs and network traffic with timely alert notifications
- AWS WAF for web application firewall protection

35. Is there an DMZ environment within the network that transmits, processes, or stores Scoped systems and data e.g., web servers, DNS, directory services, remote access, etc.?

Partially applicable. The architecture includes:

- All ChemAIRS Kubernetes containers set to ClusterIP to ensure security (only accessible by authorized services in cluster)
- Only frontend web services are exposed via ClusterIP/NodePort
- Ingress-Nginx used as a solution for controlled access to cluster services
- Internal services (RabbitMQ, Redis, database, etc.) are not accessible from outside the cluster

36. Is there a wireless policy or program that has been approved by management, communicated to appropriate constituents and an owner to maintain, and review the policy?

Not applicable.

37. Are there security standards, baseline configurations, patching, access control, and strong passwords for network devices such as Firewalls, Switches, Routers, and Wireless Access Points?

Yes. Security standards include:

- Strong password policies (minimum 8 characters, at least 3 of 4 character types)
- Access control via RBAC (Role-Based Access Control)
- User tenant segregation
- Password policies enforced
- Access log auditing
- Regular patching (monthly for applications, AWS-managed for infrastructure)
- Network segmentation (VLAN segmentation and data isolation)

38. Are default passwords changed or disabled prior to placing network devices into production?

Yes. During deployment, we ensure that:

- Redis requires access password configuration (Redis does not require an account by default, but ChemAIRS creates one)
- RabbitMQ includes default account credentials that must be configured

- All middleware components require password configuration before deployment

Privacy Management

- 39. Are there documented policies and procedures that define limits to the collection and use of personal information to authorized users regarding limiting the personal information collected and used by authorized users e.g., minimum necessary, need to know, job role?**

Yes. ChemAIRS has documented policies that follow the minimum necessary principle:

- ChemAIRS only collects minimal personal information necessary: name, email address, and company name
- Data access is controlled through RBAC (Role-Based Access Control) with different permission levels for different roles (researchers, project managers, administrators)
- Data access privilege is one-time and each access requires submission of business justification and CEO authorization
- System administrators have maintenance privileges but do NOT have access to specific client data
- Access rights are refined for operations such as data reading, editing, and deletion based on job role
- For sensitive data, access is restricted to specific roles only

(note: we can use data processing agreement as evidence)

Threat Management

- 40. Is there a centrally managed Vulnerability Management Program and associated Policy that has been approved by management, communicated to appropriate constituent and an owner assigned to maintain and review the policy?**

Yes. ChemAIRS has a comprehensive vulnerability management program:

- Code-level scanning: SonarQube is integrated into the CI/CD pipeline to review submitted code, identifying and remediating potential security vulnerabilities
- Container scanning: The built container images are scanned using the Trivy automation tool with the latest real-time CVE vulnerability database to analyze potential security vulnerabilities and fix them before deployment
- Regular scanning: Quality management team performs security vulnerability scans on pre-release and online environments

- Third-party assessments: Annual application security assessments combining tools and manual testing by professionals
 - Third-party penetration tests: Conducted every 6 months
 - Threat intelligence: Subscription to latest threat intelligence feeds to learn about active malware and vulnerability exploits
 - Ownership: Data security team reviews vulnerabilities and submits to code owners for repair; changes require approval from development lead and data security lead
- 41. Does the organization maintain policies, standards, and procedures for identifying and managing cyber supply chain risks i.e., ensuring software and hardware components used as part of delivering a service or product do not present a risk?**

Yes. ChemAIRS implements security measures for software components:

- All software dependencies and container images are scanned for vulnerabilities using Trivy with the latest real-time CVE vulnerability database before deployment
- Code security team reviews reference chain vulnerabilities identified in daily reports
- The organization uses OWASP scanning standards with each software version release

Server Security

- 42. Are server security standards reviewed and/or updated at least annually to account for any changes in environment, available security features and/or leading practices?**

Yes. Security policies and standards are reviewed regularly:

- Policies are reviewed and updated regularly to address emerging threats
- Annual application security assessments are conducted
- Performance metrics like incident response times and vulnerability remediation rates are tracked
- The organization follows ISO 27001 guidelines which require regular review

- 43. Are all unnecessary/unused services uninstalled or disabled on all servers?**

Yes. We disable unnecessary functions by remove permissions under roles.

Additionally, all ChemAIRS Kubernetes containers except web services are set to ClusterIP to ensure they're only accessible by authorized services within the cluster, effectively disabling external access to unnecessary services.

- 44. Are vendor default passwords removed, disabled, or changed prior to placing any device or system into production?** [客户标注 high risk, 客户评论 Please provide evidence that vendor default passwords are removed, disabled, or changed prior to placing any device or system into production]

Yes. During deployment, we ensure that:

- Redis: "Create a Redis configuration file that includes an access password (Redis does not require an account by default)"
- RabbitMQ: Default account credentials must be configured during installation
- All middleware components require password configuration before deployment

45. Are all systems and applications patched regularly? [客户标注 high risk, 客户评论 Please provide evidence that all systems and applications are patched regularly]

Yes. ChemAIRS has a comprehensive patching program (we detect vulnerabilities and patch regularly):

- Infrastructure patches: For AWS-based deployments, frequency determined by AWS push mechanism
- Application patches: Container images with patches are typically updated automatically with each version release (usually monthly)
- Vulnerability-driven patches: Critical vulnerabilities identified by SonarQube and Trivy are fixed before release
- Regular scanning: Quality management team performs regular security vulnerability scans

46. Is there an anti-malware policy or program including a means of protection through the use of electronic transfer, that has been approved by management, communicated to appropriate constituents and has an owner to maintain, and review the policy? [客户标注 high risk, 客户评论 Please provide evidence of anti-malware policy]

Yes. ChemAIRS has anti-malware protection:

- Advanced hardware firewalls employed
- Data security team conducts continuous surveillance for unusual activities
- AWS GuardDuty used for threat detection
- AWS WAF for application-level protection
- Malware scans on data and databases are also performed

Cloud Services

47. Are Cloud Hosting services provided? Please explain the service and may provide a security concept.

Yes. ChemAIRS provides SaaS (cloud hosting)

SaaS Cloud Hosting Service:

- Hosted on AWS (Amazon Web Services) in North California (us-west-1) region
- Uses AWS managed services including:
 - AWS RDS for database with high availability
 - AWS EKS for Kubernetes orchestration
 - Multi-copy instances across different availability zones
 - AWS CloudWatch for monitoring
 - AWS GuardDuty for intrusion detection
 - AWS WAF for web application firewall

Security Concept:

- Data encrypted in transit (TLS 1.3/1.2, AES 256) and at rest (private encryption algorithm, hashed and salted)
- Multi-tenant isolation through tenant segregation (different tenants cannot access each other)
- Internal-only private network (VPC) based cluster deployment
- All services except web frontend use ClusterIP (internal-only access)
- Daily automated backups with 7 generations stored in multiple physically isolated availability zones
- Distributed containerized architecture for quick disaster recovery

48. Does the Cloud Hosting Provider provide independent audit reports for their cloud hosting services e.g., Service Operational Control - SOC? [客户标注 high risk, 客户评论 Please provide evidence of independent audit reports of your Cloud Hosting Provider]

No, we have the ISO27001 certificate in lieu of the SOC certification, as most of our clients choose local deployment rather than a SaaS over the internet.

Software and Cloud Application Development Standards

49. Is application development performed?

Yes. ChemAIRS is actively developed software with continuous updates and improvements.

50. Is there a secure software development lifecycle policy that has been approved by management, communicated to appropriate constituents and an owner to maintain, and review the policy? [客户标注 high risk, 客户评论 Please provide a secure software development lifecycle policy]

Yes. ChemAIRS has a comprehensive secure SDLC with multiple security controls:

- SonarQube integrated into CI/CD flow for code review and vulnerability identification

- Trivy automation tool scans container images for vulnerabilities before release (with the latest real-time CVE vulnerability database)
- Quality management team performs regular security vulnerability scans
- Code security team reviews vulnerabilities before submission to code owners
- Configuration and updates require internal modification approval process
- Changes only made after being reviewed and approved by development lead and data security lead
- Annual application security assessments combining tools and manual testing

(note: 我们先用 [📄 ChemAIRS SaaS Environment Data Security Management Regulations](#) 试一下)

51. Are the development, testing, and staging environments kept separate from the production environment? (Please provide evidence validating the implementation of the stated control)

Yes. DEV, Test and QA environments run on our own physical servers hosted in the data center, while pre-release (staging) environments are deployed in proprietary test clusters under the same AZ, replicating the base settings of the official environment to ensure that no unexpected failures will occur due to differences in the environments. The ISO 27001 certification provides independent, third-party verification that environment separation controls are properly implemented, maintained, and regularly audited.

52. Does the software development standard ensure that the application has to maintain a user audit trail? Provide supporting documentation as evidence to validate the implementation of the stated control

Yes. All access to sensitive systems and data is logged and monitored. The tenant administrator can submit a request to review. audit logs include user identification, event type, timestamp, source and destination (IP address, device, target system), and outcome (success or failure). We have internal audit logs that are not publicly available, but we can share them upon request.

53. Does the software development standard ensure that the application has to maintain an admin audit trail? Please provide evidence validating the implementation of the stated control. [客户标注 high risk, 客户评论Please provide evidence that the software development standard ensure that the application has to maintain an admin audit trail.]

Yes. The system maintains admin audit trails. All access and operation records are retained and used as the basis for admin auditing. Admin-specific logging includes privileged access and system administration activities.

54. Does the software development standard ensure that the application has to maintain a data audit trail? Please provide evidence validating the implementation of the stated control.

Yes. Audit logs will be stored in exclusive databases, only audit administrators can access it. The logging includes, data access events, user who accessed the data, timestamp of access, source IP and device information, target data accessed, operation performed (read, modify, delete). Log retention is 6 months by default (depends on storage size), with logs stored in plain text format supported by third-party logging and monitoring platforms.

55. Does the software support secure authentication methods and protocols (LDAPS, SAML, OAuth)?

Yes. ChemAIRS supports multiple secure authentication methods:

- SSO (Single Sign-On): Integrated SSO support, Azure AD fully tested
- OAuth: Supports OAuth 2.0 (Others that satisfy OAuth 2.0 are also supported)
- SAML: Supported through Azure AD integration
- LDAP: Supported as integrated SSO authentication
- Password authentication with security policies (complexity, expiry)
- MFA (Multi-Factor Authentication): In development (like Google Authenticator)
- API authentication: Supports Token or API Key methods, Bearer token in API call scenarios

56. Do you have standards for secure (web-) application development? Do you follow the recommendations of OWASP (Open Web Application Security Project) or WASC (Web Application Security Consortium)? [客户标注 high risk, 客户评论Please provide evidence that you have standards for secure (web-) application development.]

Yes, we adhere to the leading industry practices and secure coding standards during our application development process. Our data security team rigorously conducts standard OWASP scans with each software version release, proactively addressing critical vulnerabilities. We also manage other vulnerabilities based on security assessments, with a detailed strategy for each—immediate repair, scheduling for the next release, or justified non-action for no-impact findings. All actions are meticulously documented for integrity and traceability.

Detailed security practices include:

- Strict input validation with input whitelisting
- Parameterized queries to prevent SQL injection
- CSP (Content Security Policy) enabled
- CSRF protection blocked on the web

- Key APIs have authentication enabled
- Protection against code injection attacks

57. What mechanisms do you have in place to secure databases and application access to the data?

Multiple security mechanisms:

Database Security:

- Access control: Only authorized administrators with proper authorization can access databases
- Password protection: All databases require strong passwords
- Encryption: Data encrypted at rest using private encryption algorithm, hashed and salted format
- Network isolation: Database access restricted to specific IP CIDR ranges
- Connection security: TLS encryption for database connections
- Parameterized queries: Prevents SQL injection
- Minimum privileges: Accounts granted minimum necessary access rights
- Audit logging: All database access logged and monitored

Application Access:

- RBAC (Role-Based Access Control)
- Tenant isolation in SaaS environment
- Authentication required for all access
- Session management: Auto logout after 30 minutes idle
- Single device login: Each account can only be logged in on one device
- VPC isolation: Internal-only private network access
- Encryption in transit: HTTPS with TLS 1.3/1.2

58. Do you have procedure for source code reviews? Provide supporting documentation as evidence to validate the implementation of the stated control

Yes. Comprehensive code review procedures:

SonarQube is integrated into the CI/CD pipeline to review submitted code, identifying and remediating potential security vulnerabilities. After the release is completed, the built container images are scanned using the Trivy automation tool with the latest real-time CVE vulnerability database to analyze potential security vulnerabilities and fix them before deployment. The quality management team regularly performs security vulnerability scans

on both pre-release and production environments to ensure timely detection and remediation of unexpected security vulnerabilities.

Code review process:

- Automated scanning via SonarQube during CI/CD
- Daily vulnerability reports generated
- Code security team review of identified issues
- Submission to code owner for repair
- Merge approval only after repair completion
- Container scanning via Trivy before release
- Standard OWASP scans with each version release

59. Does the development standard ensure possible transfer of the application to another platform?

Yes. ChemAIRS is built with platform portability:

- Uses containerized architecture (Kubernetes-based) which enables platform independence
- Supports deployment in multiple environments:
 - AWS cloud services
 - Local deployment on customer infrastructure
 - Multiple Linux distributions (Rocky Linux, Debian, CentOS, Ubuntu)
- Database portability: Uses PostgreSQL which is platform-independent
- Docker containers: Ensures consistent deployment across platforms
- Configuration-driven deployment enables adaptation to different platforms

To transfer ChemAIRS to another platform, the following requirements must be fulfilled: x86_64 architecture with at least one NVIDIA GPU server; supported Linux distributions (Rocky Linux 8.9-9.3, Debian 11-12, CentOS 7.9, or Ubuntu 18.04-22.04) with kernel $\geq 3.10.x$; Kubernetes orchestration (RKE2 or cloud-managed services like AWS EKS/Google GKE/Azure AKS) with containerd engine; PostgreSQL 14.0+ supporting 512 concurrent connections (self-hosted or cloud service); persistent storage supporting Kubernetes PV/PVC with RWX permissions (NFS/Local storage for on-premises, or AWS EFS/Google Cloud Storage/Azure Disk for cloud); Redis and RabbitMQ middleware with proper authentication configured; network infrastructure with static IP, DNS, and appropriate firewall configurations; NVIDIA GPU drivers, Container Toolkit, and CUDA runtime for GPU functionality; and access to ChemAIRS deployment configuration files and container registry credentials.

60. How often do you provide software increments / new releases?

Monthly. Applications are built as container images whose patches are typically updated automatically with each version release, usually at a frequency of once a month

61. Do you ensure that the software is running on supported OS and database releases?

Yes. ChemAIRS has specific requirements:

Operating Systems:

- Supports most mainstream glibc-based Linux operating systems
- Recommended: Rocky Linux (8.9 - 9.3), Debian (11-12), CentOS 7.9, Ubuntu (18.04 - 22.04)
- These are thoroughly tested and validated systems

Database:

- PostgreSQL minimum version: 14.0
- PostgreSQL 14+ chosen for improved multi-threading and large-scale concurrent queries
- Cloud options: AWS RDS, Google Cloud SQL for PostgreSQL

62. Do you have a fall back plan for new releases?

Yes. Multiple fallback mechanisms:

- Backup before updates: Database operated and backed up before changes
- Pre-release testing: Deployed in test clusters that exactly replicate production settings
- Daily backups: 7 generations of daily backups maintained
- Automated recovery tests: Quality management team performs regular automated recovery tests
- Rollback capability: Container-based architecture allows easy rollback to previous versions
- Separation of environments: Pre-release environment tested before production deployment

What provisions do you make in the software to reduce the upgrade risk?

63. Can the software run independently from the (admin) account that was used for the installation (relevant for software to be installed on a Windows Operating System)?

Yes. The architecture demonstrates service account independence:

- ChemAIRS runs as containerized services under specific user (UID=65534, GroupID=65534)

- Services run independently of installation account
- Database services run under dedicated postgres user
- Kubernetes services run under service accounts
- Installation and runtime accounts are separate

Software and Cloud Application Architecture

64. Is an Application Programming Interface (API) available to clients and how is it secured? [客户标注 high risk, 客户评论Please provide evidence on how the API is secured.]

Yes. ChemAIRS provides comprehensive API access with robust security:

API Availability:

- Platform supports direct function and data access via API calls
- Standard RESTful architecture
- Data format: JSON
- HTTPS secure transmission supported

API Security:

- Authentication required: API access is disabled by default and requires separate applications for activation
- Authentication methods: Supports Token or API Key methods
- Bearer token: Used in API call scenarios
- Rate limiting: Platform imposes rate limits on API calls per account
- Scope limitation: API keys only give access to the scope of the API being called (secrets limited to respective scopes)
- HTTPS enforcement: All API communication over HTTPS with TLS encryption
- Input validation: Strict input validation and whitelisting on all input portals

Test Plans and Standards (for Software and Web Application)

65. Do you have standards for test planning and execution? (Please provide evidence validating the implementation of the stated control.) [客户标注 high risk, 客户评论Please provide evidence of standards for test planning and execution]

Yes. ChemAIRS has comprehensive testing standards implemented through their SDLC:

Evidence of testing standards:

- Separate test environments: DEV, Test, QA, and Pre-release environments are maintained separately from production
- Pre-release testing: Pre-release environments are deployed in proprietary test clusters under the same AZ, replicating the base settings of the official environment to ensure that no unexpected failures will occur due to differences in the environments
- Quality management team: Dedicated team performs regular security vulnerability scans and testing
- Automated recovery tests: The quality management team performs automated recovery tests on the backup copies on a regular basis to verify the availability of the recovered system

Please provide examples of test plans for each phase (structure test (white box test), module and integration test).

Example: Structure Test (White Box Test)

Scope: Individual component code analysis and internal logic verification

Test Plan Activities:

- Static Code Analysis: Automated scanning of source code for security vulnerabilities and coding standard violations before merge
- Code Review: Mandatory peer review of all code changes focusing on:
 - Input validation implementation
 - SQL injection prevention (parameterized queries verification)
 - Error handling without exposing sensitive data
 - Proper implementation of authentication/authorization logic
- Unit Testing: Developer-created tests for individual functions and methods
 - Database layer: PostgreSQL query validation and data integrity checks
 - Middleware components: Redis caching logic, RabbitMQ message handling
 - API endpoints: Request/response validation
- Security Testing: Verification of security controls implementation:
 - Credential management (Kubernetes secrets usage)
 - Access control logic (ClusterIP restrictions)
 - Data encryption routines

Test Environment: Local development environment with isolated database schemas

Test Data: Synthetic data following Data Classification Standard (no production data)

Success Criteria:

- 100% code review completion before merge
- Zero critical security vulnerabilities from static analysis
- Minimum 80% code coverage for security-critical components

66. Are security tests (negative tests, check sum tests, code or SQL injection tests, brute-force attacks, buffer-overflow protection, cross-site scripting, key generation in cryptographic modules) part of each test plan?

Yes. ChemAIRS includes comprehensive security testing:

Security tests implemented:

- SQL Injection protection: Use of parameterized queries → All database queries are parameterized (e.g., precompiled statements) to avoid splicing user input
- Cross-site scripting (XSS) protection: CSP is enabled and CSRF is blocked on the web
- Input validation: Strict input validation → Input whitelisting is enabled on all input portals to ensure that user input conforms to the expected type and format
- OWASP scanning: Our data security team rigorously conducts standard OWASP scans with each software version release, proactively addressing critical vulnerabilities
- Vulnerability scanning:
 - SonarQube integrated into CICD for code vulnerability detection
 - Trivy for container image vulnerability scanning
 - Regular security vulnerability scans on pre-release and online environments
- Penetration testing: Annual application security assessment combining tools and manual testing by professionals and third party penetration tests conducted every 6 months
- Brute-force protection: Account lockout after 5 incorrect password entries (It should be unlocked by enterprise tenant administrators); CAPTCHA functionality under development

67. Do you document test results as part of quality documentation? Please provide evidence validating the implementation of the stated control.

Yes. Multiple forms of quality documentation:

Evidence:

- Vulnerability reports: Vulnerabilities in the reference chain are identified in daily reports and reviewed by the code security team
- Security assessment documentation: Documentation of detailed strategy for each vulnerability (immediate repair, scheduling for next release, or justified non-action). All actions are meticulously documented for integrity and traceability
- Audit logs: All testing and deployment activities are logged and retained as basis for auditing
- Pre-release validation: Quality management team validates system availability and data integrity through automated tests with documented results
- Change documentation: The configuration and updates of ChemAIRS require an internal modification approval process. Changes can only be made after being reviewed and approved by the development lead and the data security lead

68. Is a test checked by a second person?

Yes. Multiple review levels are implemented:

Evidence of dual review:

- Code security team review: Vulnerabilities in the reference chain are identified in daily reports and reviewed by the code security team before being submitted to the code owner for repair
- Approval process: Only after the repair is complete will the merge-in request be approved
- Dual approval for changes: Changes can only be made after being reviewed and approved by the development lead AND the data security lead (two separate reviewers)
- Quality management team: Separate team that performs security vulnerability scans distinct from development team

This demonstrates a clear separation of duties with multiple review checkpoints.

69. Can you prove that the test standards have been followed?

Yes. Multiple mechanisms provide proof:

Evidence of compliance:

- Audit trails: All access and operation records are retained and used as the basis for auditing
- CICD integration: Automated testing is integrated into the CICD pipeline, creating automatic documentation
- Daily vulnerability reports: Systematic generation of vulnerability reports provides documentation trail

- Security certifications: ISO 27001 certification (which requires documented evidence of testing procedures)
- Traceability: All actions are meticulously documented for integrity and traceability
- Third-party validation: Annual application security assessments and bi-annual penetration tests by external professionals provide independent verification
- Pre-release validation records: Automated recovery tests with documented verification results

Nth Party Management

70. For external software developer, is there a contractual relationship that defines obligations especially regarding secure software development standards?

No external software developers are used. ChemAIRS develops all software in-house with their own development team.

QUESTIONNAIRES

0/2 Completed0%

CERTIFICATIONS & ASSURANCE REPORTS

0/1 Completed0%

INSURANCE POLICIES

0/1 Completed0%

AUDITS & ASSESSMENTS

0/1 Completed0%

Certifications & Assurance Reports

Requested

ISO 27001 and Statement of...

Requirement



Requested

SOC-1 / ISAE 3402 - Type II

Requirement



Requested

SOC-2 - Type II

Requirement



Insurance Policies

Requested

Business Interruption

Requirement



Requested

Commercial General Liability

Requirement



Requested

Cyber Liability / Data Privacy

Requirement



Audits & Assessments

Requested

General Security Audit

Requirement



Requested

Network Vulnerability Scan

Requirement



Requested

Penetration Test

Requirement



客户反馈高风险问题清单

📁 高风险问题清单